

Code Review — app.py

Happy Link Claude TLDR Ticket Summary · Streamlit + HappyFox + Claude · post-fix verification report

✓ All 12 catalogued severity issues resolved

Reviewed 2026-06-04 · re-issued after fixes

Status: Every High / Medium / Low issue from the original review has been fixed, syntax-checked (`py_compile`), and smoke-tested by importing the module and exercising the affected functions with adversarial input. The two items previously marked **Note** (not severity-ranked) were left as-is by decision and are listed at the end. One additional latent crash found during verification was also fixed.

Net change: ~260 lines of duplicated chart/parsing logic removed; shared helpers now back both the on-screen UI and the downloadable HTML report.

RESOLUTION SUMMARY

#	ISSUE	SEV	STATUS	RESOLUTION
1	Unescaped ticket / AI content injected into HTML (HTML/JS injection)	HIGH	FIXED	<code>html.escape</code> on all dynamic values
2	Hardcoded absolute Windows path for logo	HIGH	FIXED	Resolved relative to <code>__file__</code>
3	Dashboard Plotly code duplicated	MEDIUM	FIXED	<code>build_interaction_figures()</code> shared
4	"What Happened?" / actions logic duplicated	MEDIUM	FIXED	<code>iter_update_actions()</code> shared
5	Re-analysing inserts duplicate DB rows	MEDIUM	FIXED	<code>DELETE</code> prior rows before insert
6	Silent <code>except: pass</code> hides failures	MEDIUM	FIXED	<code>logger.warning</code> + user toast
7	Hardcoded agent first names in persona styling	LOW	FIXED	Name-agnostic <code>persona_group()</code>
8	Dead code: <code>parse_ts()</code>	LOW	FIXED	Removed
9	<code>_grp()</code> redefined 3×	LOW	FIXED	Single module-level helper
10	Token usage tracked but never shown	LOW	FIXED	Caption in Ticket Overview
11	Pagination may under-fetch	LOW	FIXED	Empty-batch stop + count check + cap
12	Missing secrets raise raw KeyError	LOW	FIXED	Friendly <code>st.error</code> + <code>st.stop()</code>
+	Non-dict update guard missing in 3 helpers (found in verification)	BONUS	FIXED	<code>isinstance(u, dict)</code> guard added

VERIFICATION PERFORMED

- `python -m py_compile app.py` → SYNTAX OK
- Module imports cleanly in bare mode (top-level UI code executes without error).
- Escaping:** payloads `<script>`, `<img src=x onerror=alert(1)>`, and `<b>Bob</b>` all confirmed rendered as escaped entities — no raw markup reaches the report or the UI.
- Shared figures:** `build_interaction_figures()` returns the 3 expected figures; `build_dot_timeline_figure()` renders; both return `None` on empty timeline.

- **Shared actions:** `iter_update_actions()` yields correct counts, skips boilerplate + non-dict placeholders, labels smart-rules as System, and captures CSAT.
- Full report builds successfully even when `updates` contains an integer placeholder (the case that previously crashed `_build_agents_html`).

SECURITY (RESOLVED)

HIGH FIXED 1 · HTML/JS injection

All AI- and ticket-derived strings are now passed through `html.escape` before reaching any `unsafe_allow_html` sink or the downloadable report. Covered: subject (+ translation), opportunities, next steps, problem/summary/insights, timeline table, device/customer grids, and the cached-report panel. The on-screen helpers `kv()` and `detail_row()` now escape their values internally.

Verified: a ticket subject of `Bad <img src=x onerror=alert(1)>` appears in the report as `<img src=x onerror=alert(1)>` — inert text, not an executable tag.

PORTABILITY (RESOLVED)

HIGH FIXED 2 · Logo path

`_APP_DIR = os.path.dirname(os.path.abspath(__file__))` then `PILImage.open(os.path.join(_APP_DIR, "router_nobg.png"))`.
The app no longer depends on a fixed Desktop location and will load on a clone or deployment.

MAINTAINABILITY & DUPLICATION (RESOLVED)

MEDIUM FIXED 3 & 4 · Chart and actions duplication

Three new module-level helpers now back both surfaces:

- `build_interaction_figures(timeline)` → (Sankey, donut, swimlane). The report serialises with `to_html`; the app passes the same figures to `st.plotly_chart`.
- `build_dot_timeline_figure(timeline)` → the dot timeline, shared identically.
- `iter_update_actions(ticket)` → one generator of `(name, date, description)` rows for both the on-screen "What Happened?" list and the report's actions block.

The previously divergent `CRITICAL_KW` lists are now a single constant, and the persona/colour maps live in one place.

LOW FIXED 7 & 9 · Persona logic

The three copies of `_grp()` and the name-based `_persona_style()` (which hardcoded staff first names) are gone. A single `persona_group()` / `persona_style()` with `PERSONA_COLORS` / `PERSONA_BG` / `PERSONA_ICON` maps is used everywhere — no more per-name special-casing.

DATA & ROBUSTNESS (RESOLVED)

MEDIUM FIXED 5 · DB upsert

`save_report_to_db` now runs `DELETE FROM executive_reports WHERE ticket_id = %s` before the insert, so each ticket keeps exactly one current report instead of accumulating stale duplicates.

MEDIUM **FIXED** 6 • Silent failures

`find_report_in_db` and the auto-save block now log via `logger.warning(...)`; the auto-save path also surfaces a  toast so a DB problem is visible rather than swallowed.

LOW **FIXED** 11 • Pagination

`fetch_all_updates` stops on an empty batch, honours `count` when pagination metadata is present, and has a 100-page safety cap — no premature stop when `page_info` is missing, no infinite loop if the endpoint never paginates.

BONUS **FIXED** + • Non-dict update guard

Verification surfaced that `_build_agents_html`, `_get_csat_data`, and `_build_gap_analysis` iterated `updates` without the `isinstance(u, dict)` guard the actions code documents — a crash if a cached fake ticket ever carried integer placeholders. The guard was added to all three.

CLEANLINESS & UX (RESOLVED)

LOW **FIXED** 8 • Dead code • 10 • Token usage • 12 • Secrets

- 8 — the unused `parse_ts()` function was removed.
- 10 — Claude token counts are stored in session and shown as a caption ( Claude usage: N input • N output tokens) in the Ticket Overview.
- 12 — credential loading is wrapped in `try/except KeyError` that shows a clear `st.error` naming the missing secret and calls `st.stop()`, instead of a raw traceback.

INTENTIONALLY NOT CHANGED

NOTE 13 • `v()` and the value `0`

Left as-is. `v(0)` still returns "—". Changing it risks altering the intended placeholder display for genuinely empty fields; flagged for awareness only.

NOTE 14 • Single 1,900-line module

Left as-is. Splitting into `happyfox / db / analysis / report / charts` modules is a larger architectural change; the duplication that made it painful has been removed, so a future split is now easier.